

Gelos Enterprises

Incident Response Plan

Version: 1.0

Date: 16/06/2020

Prepared for: Gelos Enterprises Management

Prepared by: Delta SOC

PUBLIC PORTFOLIO COPY

Introduction.....	4
1	
IRP Scope and Service Definition.....	4
1	
Business Implications of Cyber Security Incidents.....	6
1	
Incident Response Team (IRT) Structure and Communication.....	9
1	
Gelos Enterprises: Incident Response Plan (IRP)	13
1	
Blue Team Playbooks (Incident Response Procedures).....	17
1	
Appendix.....	19
1	
Introduction.....	4
IRP Scope and Service Definition.....	4
Scope of Incidents Covered.....	4
Services Provided by the Gelos IRT.....	5
Business Implications of Cyber Security Incidents.....	6
Incident Response Team (IRT) Structure and Communication.....	9
IRT Members, Roles, Responsibilities, and Training Requirements.....	9
IRT Services & Processes.....	13
Incident Response Reporting/Communication Process (Internal).....	13
Gelos Enterprises: Incident Response Plan (IRP)	13
Part 3 – Internal Processes.....	13
Incident reporting.....	13
Initial triage.....	13
Containment.....	13
Evidence preservation.....	13
Investigation.....	14
Recovery.....	14
Monitoring and review.....	14
Communication Strategies and Reporting Hierarchy (External/Cross-Departmental).....	15
Blue Team Playbooks (Incident Response Procedures).....	17
Appendix.....	19
Blue Team Playbooks (Incident Response Procedures).....	19
Playbook: Privilege escalation by Andrew Byrne.....	19
Playbook: IDOR attack on the Healthcare System by Team member.....	24

Phases:.....	24
Playbook: SQL Injection attack on the Healthcare System Team member.....	27
Playbook: Ransomware by Team member.....	30
Playbook: Reconnaissance Attack Detection and Response (by Team member).....	37
References.....	39

PUBLIC PORTFOLIO COPY

Introduction

This Incident Response Plan (IRP) provides a structured and consistent framework for managing cyber security incidents within Gelos Enterprises. The purpose of this plan is to ensure that all incidents are identified, analysed, contained, eradicated, and recovered from in an efficient and coordinated manner.

The IRP establishes defined roles, responsibilities, and procedures for responding to a range of cyber security events that may impact organisational systems and operations. These procedures are designed to support effective detection and response capabilities, minimise disruption to business activities, and reduce potential financial and reputational impact.

This plan also supports continuous improvement through structured post-incident review and refinement of detection and response controls. It establishes clear governance over incident management processes, including defined reporting procedures, accountability, and escalation pathways. The IRP is aligned with organisational policies and supports compliance with relevant legal, regulatory, and security requirements, ensuring that incidents are managed in a controlled, auditable, and consistent manner.

IRP Scope and Service Definition

Scope of Incidents Covered

This Incident Response Plan addresses a broad range of cyber security incidents that may impact the confidentiality, integrity, or availability of organisational systems and data. These incidents reflect common threat behaviours and attack techniques observed in modern environments.

The IRP covers the following incident types:

- **Reconnaissance Activity:**
Unauthorised scanning, probing, or information gathering targeting systems, services, or network infrastructure
- **Unauthorised Access (Web Application Attacks):**
Exploitation of application vulnerabilities, including SQL injection, to gain access to or manipulate backend systems and data
- **Access Control Exploitation (IDOR):**
Unauthorised access to restricted resources due to insufficient validation of user permissions
- **Malware/Ransomware Activity:**
Execution of malicious software leading to system disruption, data encryption, or operational impact

- **Privilege Escalation:**
Unauthorised elevation of privileges from a non-privileged account to administrative or root-level access

Services Provided by the Gelos IRT

When a cyber security incident is confirmed at Gelos Enterprises, the Incident Response Team (IRT) steps in to manage the situation from start to finish. The IRT is not solely a technical team — it coordinates across ICT, legal, communications, and senior leadership to ensure the organisation responds in a controlled and effective manner. The core services the IRT delivers are outlined below.

- **Preparation & Readiness:** The IRT maintains up-to-date response plans, conducts regular training exercises, and ensures detection tools such as SIEM and antimalware software are properly configured before any incident occurs. This includes reviewing Gelos internal policies such as the ICT Risk Management Policy and Cyber Security Policy and Procedure on an ongoing basis (Gelos Enterprises, n.d.).
- **Incident Detection & Classification:** When a potential incident is reported — whether by a staff member such as Fernando Remi reporting login and system issues, or by an automated SIEM alert — the IRT validates the report, confirms whether a genuine incident has occurred, and assigns a severity level in line with the Gelos ICT Support SLA Policy. Critical incidents require an immediate response within 15 minutes (Gelos Enterprises, n.d.).
- **Investigation & Forensic Analysis:** The IRT conducts a thorough technical investigation to determine what happened, how the attacker gained access, what data or systems were affected, and how far the compromise spread. Evidence is collected in a forensically sound manner with strict chain of custody documentation to support legal proceedings if required (ACSC, 2023; Gelos Enterprises, n.d.).
- **Containment & Damage Limitation:** The IRT acts promptly to isolate affected systems, revoke compromised credentials, and block attacker access — limiting the spread of the incident across the Gelos network while preserving digital evidence for the ongoing investigation (Gelos Enterprises, n.d.).
- **Eradication & System Recovery:** Once the threat is fully understood and removed, the IRT rebuilds or restores affected systems from verified clean backups, applies patches to close the exploited vulnerabilities, and verifies systems are secure and fully functional before returning them to production (Gelos Enterprises, n.d.).
- **Regulatory & Stakeholder Communication:** The IRT coordinates all internal briefings to Senior Management and all external notifications to regulators such as the Office of the Australian Information Commissioner (OAIC) under the Notifiable Data Breaches (NDB) scheme, law enforcement such as the Australian Federal Police (AFP) and Australian Cyber Security Centre (ACSC), and affected customers — ensuring Gelos meets its obligations under the Privacy Act 1988 (Cth) (OAIC, 2024; AFP, 2024).

- **Post-Incident Review:** After every incident, the IRT conducts a lessons learned session to identify what failed, what worked, and what must change — updating playbooks and security controls to reduce the likelihood and impact of future incidents (Gelos Enterprises, n.d.).

Business Implications of Cyber Security Incidents

The suspected data breach at Gelos Enterprises is not simply an IT problem. What Lee Dowling's investigation uncovered — outdated software, unapplied security patches, and a likely malware infection — represents a failure of organisational controls that has placed up to 3.4 million customers at risk, including 15,000 valid driver's licence numbers and 10,000 passport numbers (Gelos Enterprises, 2025). The business consequences of this incident, and of future incidents if adequate controls are not implemented, are significant across four key areas.

- **Financial Impact:**
 - **Direct Costs:** The immediate costs of this incident include digital forensic investigation, legal counsel, regulatory compliance, customer notification, and system recovery. According to the IBM and Ponemon Institute Cost of a Data Breach Report (2023), the global average cost of a data breach reached USD \$4.45 million. For a breach of the scale suspected at Gelos — affecting millions of customers with highly sensitive government identity documents — direct costs could be substantially higher (IBM Security, 2023).
 - **Indirect Costs:** Beyond immediate expenditure, Gelos faces ongoing financial damage through lost productivity during system downtime, potential loss of business contracts from clients who require assurance of data security, and the long-term cost of restoring customer confidence. Every day systems remain compromised or unavailable represents revenue that cannot be recovered (Ponemon Institute & IBM, 2023).
- **Reputational Damage:**
 - **Loss of Customer Trust:** Gelos provides services to businesses and individuals across Australia. When it becomes public that Gelos failed to protect up to 3.4 million customer records — including highly sensitive government identification documents — many clients will question whether Gelos can be trusted as a service provider. Research consistently shows that customer trust, once lost after a data breach, is extremely difficult to rebuild (Ponemon Institute & IBM, 2023).

- o **Brand and Market Impact:** Negative media coverage following a breach of this scale can cause lasting damage to Gelos's corporate image, impacting investor confidence, partner relationships, and competitive positioning. Organisations that have experienced major public data breaches have reported declining client numbers for several years afterwards, with brand recovery taking far longer than technical recovery (IBM Security, 2023).
- **Legal and Regulatory Consequences:**
 - o **Notifiable Data Breaches Obligations:** Under the Privacy Act 1988 (Cth) and the Notifiable Data Breaches (NDB) scheme, Gelos is legally required to notify the OAIC and affected individuals as soon as practicable once a data breach that is likely to result in serious harm is confirmed. Failure to meet these obligations, or unreasonable delays in notification, can itself constitute a breach of the Act (OAIC, 2024).
 - o **Financial Penalties:** Serious or repeated interferences with privacy under the Privacy Act 1988 (Cth) carry civil penalty provisions. Penalties can reach up to AUD \$50 million, or three times the value of any benefit obtained from the breach, or 30% of the body corporate's adjusted turnover during the breach period — whichever is greatest (Privacy Act 1988 (Cth)).
 - o **Litigation Risk:** Customers whose government identification documents and personal information have been compromised may pursue legal action against Gelos. Given the scale of the suspected breach and the severity of the potential harm — including identity theft — class-action litigation is a realistic risk that could far exceed the direct cost of incident response (OAIC, 2023).
- **Operational Disruption:**
 - o **System Unavailability:** The Gelos incident demonstrates how quickly a cyber security failure can bring operations to a halt. Fernando Remi was unable to access the Gelos network, systems became progressively slower and eventually shut down unexpectedly, and Lee Dowling was unable to resolve the issue using standard administrator privileges (Gelos Enterprises, 2025). Scaled across the organisation, this level of disruption means staff cannot perform their duties, customer-facing services go offline, and revenue generation stops entirely.

- o **Resource Diversion:** Managing a major cyber incident consumes the time and attention of key ICT, legal, and executive personnel who would otherwise be driving business operations. The opportunity cost of diverting these resources to crisis management — combined with the external costs of engaging specialists such as DataTrust — represents a significant and largely unavoidable financial burden when an incident occurs without a prepared response plan in place (Gelos Enterprises, 2025).

An effective and regularly tested Incident Response Plan is not merely a technical requirement — it is a critical business safeguard. The cost of preparation is far lower than the combined financial, legal, reputational, and operational cost of responding to an incident without one.

PUBLIC PORTFOLIO COPY

Incident Response Team (IRT) Structure and Communication

IRT Members, Roles, Responsibilities, and Training Requirements

Role	Responsibilities	Training Requirements
Incident Commander	- Establishes authority and control, defines incident objectives, and managing their team's strategy. - Ensures stakeholders are informed and that information flows efficiently among team members. - Delegating resources and specific tasks to relevant team members who specialises in these tasks - Resolve incidents by making critical and timely decisions - Update the incident action plan. - Lead the post-incident activities to identify root causes and lessons learned from incidents	- Short course on managing emergency incidents such as the below courses: https://ergt.edu.au/courses/manage-emergency-incidents https://hostsafetytraining.com.au/product/emergency-commander-ec-incident-commander-training-ict/
Security Analyst	- Protects an organisation's assets, networks, and data - Monitoring network traffic and systems for malicious activity and unusual patterns to identify cyber threats.	- Bachelors Degree in IT, specifically in Cyber Security. - Internships to gain real-world work experience while studying.

	• Install and maintain security software for systems such as firewalls and intrusion detection systems. • Create and enforce security policies, protocols, and best practices to ensure compliance among the community with industry regulations • investigating security incidents, and implementing protective measures	• Industry-relevant certifications, such as CompTIA Security and Cisco.
IT Systems Specialist	• Make sure that system configurations, IT policies and other technical documentation are accurate. • Prevent major business disruptions by maintaining backup procedures. • Install, configure and update hardware, software and network devices. • Provide IT support to users of all skill levels. • Implement and maintain security measures like firewalls and user privileges to protect organisational assets from cyber attacks.	• Certificate IV or Diploma in IT or Cybersecurity. • Bachelors Degree in IT or Computer Science. • Internships to gain real-world work experience while studying. • Industry-relevant certifications, such as CompTIA Security and Cisco.
Network Specialist	• Install, configure and update network devices such as routers, switches and firewalls.	• Bachelors Degree in IT or Network Engineering. • Internships to gain real-world work experience

	• Monitor and analyse network traffic and performance, and prevent network issues to ensure 100% uptime of systems. • Set up firewalls, VPNs and perform vulnerability tests to secure data and networks against cyber threats. • Provide support and diagnose network faults for network problems. • Upgrade network and software to meet future scalability needs and requirements of organisations.	while studying especially to gain skills using network, server and cloud administration software. • Industry-relevant certifications, such as CompTIA Network+ and Cisco.
Legal Specialist	• Make sure that business comply with local, state and federal laws and regulations to avoid being subjected to fines and punishment. E.g. identify potential legal risks in business strategies / decisions and commercial agreements like vendor contracts • Provide legal advice on intellectual property, corporate governance and other related law. • Ensure that legal and corporate documents / records are up to date.	• Certificate IV in Legal Services to learn the Australian Legal System.

Communications Lead	• Increase organisations' reputation by developing and implement communication strategies that aligns with their goals. • Creative in creating content for websites, social media and news releases to enhance an organisation's branding and maintain relationships with their clients. • Analysing and evaluating the organisation's communications to improve their future communications campaigns.	• Bachelors Degree in Communications with option for Masters Degree in Communications. - o Alternatively, there are other courses available at affordable costs such as Certificate IV in Marketing and Communication
----------------------------	---	--

PUBLIC PORTFOLIO COPY

IRT Services & Processes

Incident Response Reporting/Communication Process (Internal)

Gelos Enterprises: Incident Response Plan (IRP)

Part 3 – Internal Processes

Incident reporting

At Gelos Enterprises, the internal process begins the moment a staff member suspects a cyber security incident. The staff member must immediately contact the ICT Service Desk Officer, complete the Incident Report form, and inform their manager. Gelos policy also requires staff not to delete, move, or alter suspicious emails, files, or other evidence, because these may be needed for the investigation. Staff must also avoid trying to fix the issue themselves on a Gelos PC's and must not contact clients or external bodies about the incident.

Initial triage

Once the report is received, the ICT Service Desk must record the incident and decide whether it is a routine technical issue or a genuine cyber security threat. If the event appears suspicious or serious, it must be escalated to the ICT Security Senior Manager, who coordinates the response and decides whether further action is required. Gelos ICT Risk Management Policy states that all users must report malfunctions and cyber intrusions immediately, and that management must use those reports to support risk decisions.

Containment

After escalation, Gelos must contain the incident quickly so it does not spread. This may involve isolating the affected device, disabling compromised accounts, blocking suspicious senders, restricting network access, or preventing further logins to affected systems. Gelos data protection rules require access to be limited to authorised users only, so containment should immediately apply need-to-know access controls and strong account protection measures. The goal is to stop further damage while preserving the original state of the system for investigation.

Evidence preservation

Gelos must preserve all relevant evidence from the start of the response. This includes suspicious emails, system logs, alerts, screenshots, account records, and any malware samples linked to the incident. Gelos policy specifically states that suspicious files must not be moved or deleted because they may be required as evidence. Sensitive evidence should be handled carefully because Gelos classifies personal information and sensitive company data as protected information that must only be accessed by authorised staff.

Investigation

Once the evidence is secured, Gelos should investigate how the incident happened and what was affected. The investigation should check software versions, patch levels, antivirus status, user privileges, and any signs of malware or unauthorised access. This is important because Gelos policy requires authorised software only, current security patching, and up-to-date anti-virus software on all internet-connected systems. The investigation should also determine whether any customer PII or sensitive company data was exposed, because Gelos treats that information as highly protected.

Recovery

After the cause is identified, Gelos should remove the threat and restore systems using verified backups. The Data Backup Policy requires regular workstation and server backups, with server backups taken nightly and full backups taken weekly. It also requires backup testing, which means restored files should be checked before systems are returned to use. Recovery should include patching the weakness, resetting passwords if needed, and confirming that restored systems are clean and functional.

Monitoring and review

After recovery, Gelos should continue monitoring for unusual logins, unknown devices, suspicious transactions, and abnormal network activity. The ICT Risk Management Policy says risk monitoring must be ongoing, so post-incident monitoring is part of normal control at Gelos. The final step is a lessons learned review, where Gelos records what happened, what worked, what failed, and what must be improved in policy, patching, backup practice, or staff awareness.

External Communication and Governance

Evidence Collection and Protection Processes

Gelos Enterprises must implement formal evidence collection and preservation procedures to ensure all evidence gathered during a cyber security incident remains forensically sound and legally admissible. A documented chain of custody process should be maintained for all digital evidence collected. This documentation must record who collected the evidence, the date and time of collection, where it was stored, who accessed it, and any transfers or modifications made. Evidence should be labelled, securely stored, and protected from unauthorised access or tampering.

During an incident, volatile data should be collected before shutting down affected systems, as this information may otherwise be lost. This includes memory dumps, running processes, active network connections, logged-in users, and system time information. Approved forensic tools should be used to capture this data while minimising changes to the affected system. Forensic imaging procedures must also be followed by creating bit-by-bit copies of compromised drives or systems rather than working on the original device.

System, firewall, application, authentication, and network logs must be preserved immediately following detection of an incident. Logs should be copied to secure, access-controlled storage locations with restricted permissions and backup retention enabled. Malware samples identified during the investigation must be isolated in a secure analysis environment, such as a sandbox, to prevent accidental execution or further infection. Access to malware samples should be restricted to authorised security personnel only, and all handling activities must be documented.

Communication Strategies and Reporting Hierarchy (External/Cross-Departmental)

Gelos Enterprises should establish a clear communication strategy to ensure accurate, timely, and controlled information sharing during cyber security incidents. External communications with affected customers, regulators, law enforcement, third-party vendors, and the media must only be conducted by authorised personnel. The Incident Response Manager should coordinate all communications with assistance from executive management, legal representatives, public relations personnel, and human resources where appropriate.

A formal reporting hierarchy should be followed during incidents. Technical incident details should first be escalated internally to the cyber security response team and senior management. If the incident involves employee misconduct or insider threats, Human Resources should be notified. Public relations staff should manage media responses to protect organisational reputation and ensure consistent messaging. Legal advisors must review external communications to ensure compliance with legal and regulatory obligations.

Where personal or sensitive information is compromised, Gelos Enterprises must comply with applicable Australian legal requirements, including the Notifiable Data Breaches (NDB) scheme under the Privacy Act 1988. Eligible data breaches likely to result in serious harm must be reported to the Office of the Australian Information Commissioner (OAIC) and affected individuals as soon as practicable. Communications should only include verified information, avoid speculation, and use secure communication channels such as encrypted email, approved collaboration platforms, or official public statements.

PUBLIC PORTFOLIO COPY

Blue Team Playbooks (Incident Response Procedures)

Incident Response	Name	Summary
IDOR Attack	Team member	The user logs into the admin of the Indigo Community Services and Health Hub Electronic Medical Records (EMR) Web Application and access the patient's details by clicking their name from the patient lists page. The user then decides to access another patient's page by simply changing the fname parameter's value of the current patient page simply to access another patient's details.
Ransomware Attack	Team member	A Gelos Enterprises employee reports that files on their workstation have been encrypted and a ransom note is displayed on screen demanding cryptocurrency payment. Systems across the same network segment begin slowing down and shutting down unexpectedly. Investigation by Lee Dowling confirms a malware infection is actively spreading and encrypting critical business files across the Gelos network.
Recon	Team member	The attacker gathers information about a target system to identify vulnerabilities, open ports, services, directories, or user accounts that could be exploited later. This is often done through scanning, enumeration, and probing activities designed to map the system and prepare for a more advanced attack.
SQLi	Team member	An attacker manipulates user input fields or URL parameters to inject malicious SQL queries into the backend database. This may allow unauthorised data access, modification, or full database compromise. Detection relies on abnormal SQL patterns, unexpected database behavior, and deviations from normal application query flows.

Privilege Escalation	Andrew Byrne	An attacker exploits vulnerabilities in a system to elevate their account privileges to that of a root account. This requires some level of access having been gained via credential harvesting or could apply to insider threats that already have a legitimate point of access. Detection relies on unauthorised, non sudoer privileged commands and shells along with unusual behaviour detection.
----------------------	--------------	---

Refer to Appendix A for complete playbook as indicated.

Appendix

Blue Team Playbooks (Incident Response Procedures)

Playbook: Privilege escalation by Andrew Byrne

Scenario:

This playbook focuses on detecting unauthorised privilege escalation on a Debian-based system within the GeloS infrastructure. The scenario assumes an attacker has gained access to the target host as a non-privileged user via credential harvesting and attempts to elevate privileges to root without using legitimate mechanisms such as sudo or su. Detection is based on identifying abnormal behavioural patterns, including the execution of root-level commands from non-root accounts and changes in privilege context that cannot be explained by authorised access controls.

Preparation:

Proactive measures are implemented to enable detection of unauthorised privilege escalation on the target Debian system, including:

Log collection and monitoring

- Deployment of Elastic Agent on the host
- Centralised log ingestion and analysis through Security Onion SIEM
- Collection of process and system activity logs

Logging configuration

- Enablement of process accounting and system audit logging
- Capture of command execution, user context, and privilege levels

Baseline establishment

- Definition of normal user behaviour and system activity
- Identification of authorised privilege usage patterns

Access control validation

- Review and documentation of the system sudoers configuration
- Establishment of a whitelist of users permitted to execute commands as root

Detection capability setup

- Configuration of SIEM rules and alerts

- Identification of abnormal privilege changes, including:
 - Execution of root-level commands by non-root users
 - Privilege escalation without use of sudo or su

Detection and Analysis:

Steps are taken to identify unauthorised privilege escalation activity and determine its scope and impact, including:

Initial detection

- Monitoring SIEM alerts generated from Elastic Agent data
- Identification of suspicious behaviour such as:
 - Execution of commands as root by non-root users
 - Sudden changes in user privilege context
 - Absence of expected sudo or su usage during elevation

Log analysis

- Review of process accounting and system logs to trace command execution
- Correlation of user activity with executed processes and associated privilege levels
- Identification of abnormal command patterns, including:
 - Post-escalation verification commands (whoami, id, groups)
 - Root-level execution on user TTY sessions

Authorisation validation

- Comparison of observed activity against the system sudoers configuration
- Verification of whether the user is authorised to execute commands as root
- Detection of privilege escalation where:
 - No valid sudo rule exists
 - Commands are executed as root without sudo invocation

Behavioural analysis

- Identification of unusual execution locations (e.g. /tmp, user directories)
- Detection of anomalous execution chains leading to root access

- Assessment of command frequency and repetition indicating automated or scripted activity

Scope determination

- Identification of affected users, sessions, and processes
- Determination of whether root access has been fully established
- Identification of any associated suspicious activity (e.g. file access, system modification)

Containment:

Actions are taken to limit the impact of unauthorised privilege escalation, prevent further attacker activity, and block repeated access attempts, including:

Immediate response

- Identification of affected host and active session
- Verification of ongoing root-level activity
- Prioritisation based on severity and potential impact

Process containment

- Termination of suspicious or unauthorised processes running as root
- Identification and stopping of exploit-related or unknown binaries
- Monitoring for process re-spawning or persistence behaviour

Account containment

- Disabling or locking compromised user accounts
- Termination of active sessions associated with the affected account
- Review of authentication logs to identify additional affected accounts

Host containment

- Isolation of the compromised system from the network (logical or physical)
- Restriction of inbound and outbound network communication
- Blocking of suspicious connections or external endpoints

Access control restrictions

- Temporary restriction or removal of elevated privileges
- Validation and enforcement of sudoers policy

- Prevention of further unauthorised privilege escalation attempts

Attacker blocking and prevention

- Identification of attacker source (e.g. IP address, remote session origin)
- Blacklisting or blocking malicious IP addresses at firewall or SIEM level
- Termination and blocking of remote access methods (e.g. SSH sessions)
- Disabling vulnerable or exposed services used for initial access
- Implementation of additional access controls (e.g. restricting SSH to trusted hosts)

Monitoring and verification

- Continued observation of system activity through the SIEM
- Verification that no further unauthorised root access is occurring
- Identification of any lateral movement or additional compromised hosts

Eradication and Recovery:

Steps are taken to remove the cause of the privilege escalation and restore the system to a trusted and secure state, including:

Threat eradication

- Identification and removal of malicious files, scripts, or binaries (e.g. payloads in /tmp or user directories)
- Deletion of any exploit tools or unauthorised software used during the attack
- Removal of unauthorised user accounts created during compromise

Persistence removal

- Identification and removal of persistence mechanisms, including:
 - Malicious cron jobs or scheduled tasks
 - Modified startup scripts or service configurations
- Verification that no backdoor access methods remain

Credential and access remediation

- Reset of compromised user credentials and privileged accounts
- Review and correction of file permissions and ownership

- Validation and hardening of sudoers configuration to prevent misuse

System remediation

- Application of security patches to address exploited vulnerabilities
- Rebuilding or restoring affected systems from known clean backups where required
- Verification of system integrity and configuration consistency

Recovery of operations

- Gradual restoration of system functionality and network connectivity
- Reintroduction of the host into the production environment after validation
- Monitoring of system behaviour to ensure stability and normal operation

Verification and monitoring

- Continuous monitoring through SIEM to confirm the threat has been fully removed
- Validation that no further unauthorised privilege escalation attempts occur
- Confirmation that system activity has returned to baseline behaviour

Post-Incident Activities:

Steps are performed to review the incident, improve detection capabilities, and strengthen organisational security posture, including:

Incident review and analysis

- Completion of a detailed review of the privilege escalation event
- Correlation of logs and evidence to identify the root cause and attack method
- Assessment of how the escalation bypassed existing controls

Lessons learned

- Conduct of a lessons learned session with relevant stakeholders
- Identification of gaps in detection, monitoring, and response procedures
- Documentation of findings for future reference

Detection improvement

- Refinement of SIEM detection rules based on observed behaviour

- Enhancement of alerting for unauthorised privilege escalation patterns
- Improvement of baseline definitions for normal user and privilege activity

Control and configuration updates

- Review and hardening of system configurations (e.g. sudoers, permissions)
- Implementation of additional logging or monitoring where gaps were identified
- Strengthening of access controls and privilege management policies

Reporting and documentation

- Preparation of an incident report detailing timeline, impact, and response actions
- Documentation of all actions taken during containment, eradication, and recovery
- Communication of findings to relevant internal stakeholders

Ongoing monitoring and prevention

- Increased monitoring of the affected system and related assets
- Verification that improvements are effective in detecting similar activity
- Continuous review and update of the incident response playbook

REDACTED — peer-authored playbook is not included in the public portfolio version.

REDACTED — peer-authored playbook is not included in the public portfolio version.

REDACTED — peer-authored playbook is not included in the public portfolio version.

REDACTED — peer-authored playbook is not included in the public portfolio version.

References

- ManageEngine (2026). *Incident commander roles and responsibilities with checklist*. [online] [www.manageengine.com](https://www.manageengine.com/products/service-desk/it-incident-management/incident-commander.html). Available at: <https://www.manageengine.com/products/service-desk/it-incident-management/incident-commander.html>.
- Siddiqui, L. (2023). *The Incident Commander Role: Duties & Best Practices for ICs*. [online] Splunk-Blogs. Available at: https://www.splunk.com/en_us/blog/learn/incident-commander-ic-role.html.
- Siddiqui, L. (2023). *The Security Analyst Role: Skills, Responsibilities & Salary in 2023*. [online] Splunk-Blogs. Available at: https://www.splunk.com/en_us/blog/learn/security-analyst-role-responsibilities.html.
- TrainSmart Australia. (2025). *Cyber Security Analyst Job Description, Qualifications and Salary | TrainSmart*. [online] Available at: <https://tsa.edu.au/careers/cyber-security-analyst/>.
- Qld.gov.au. (2025). *Security analyst*. [online] Available at: <https://www.forgov.qld.gov.au/recruitment-performance-and-career/career-development/develop-digital-and-ict-capabilities/skills-framework-for-the-information-age-sfia-role-profiles/security-analyst> [Accessed 15 May 2026].
- Lumifylearn.com. (2024). *What does an IT Support Specialist do?* [online] Available at: <https://lumifylearn.com/blog/what-does-an-it-support-specialist-do-and-how-can-you-become-one/>.
- Michael Page. (2026). *The role of IT Support Specialist*. [online] Available at: <https://www.michaelpage.com.au/advice/job-description/technology/it-support-specialist>.
- Balance (2026). *Skill Finder - where you can upskill in Hundreds of digital courses for FREE*. [online] Skillfinder.com.au. Available at: <https://www.skillfinder.com.au/pathway/computer-network-specialist> [Accessed 15 May 2026].
- Upskilled.edu.au. (2026). *Network Security Specialist Job Description and Salary*. [online] Available at: <https://www.upskilled.edu.au/your-career/job-roles/network-security-specialist> [Accessed 15 May 2026].
- Hilti.group. (2026). Available at: <https://careers.hilti.group/en/jobs/16500-en/legal-specialist/> [Accessed 15 May 2026].
- Hilti.group. (2026). Available at: <https://careers.hilti.group/en/jobs/16500-en/legal-specialist/> [Accessed 15 May 2026].
- SEEK Australia. (2023). *Cyber Security Analyst*. [online] Available at: <https://au.seek.com/career-advice/role/cyber-security-analyst>.

My Training. (2024). *ICT Business and Systems Analysts*. [online] Available at: <https://mytraining.skills.sa.gov.au/occupations/ict-business-and-systems-analysts> [Accessed 15 May 2026].

Staff, C. (2024). *How to Become an IT Support Specialist: Your 2024 Guide*. [online] Coursera. Available at: <https://www.coursera.org/articles/it-support-specialist>.

SEEK Australia. (2021). *Network Specialist*. [online] Available at: <https://au.seek.com/career-advice/role/network-specialist> [Accessed 15 May 2026].

WA (2025). *Network engineer*. [online] Jobs and Skills WA. Available at: <https://www.jobsandskills.wa.gov.au/jobswa/occupations/network-engineer>.

Thirumagal Sathasevam (2024). *How to Become a Communications Manager* | UTS Online. [online] Uts.edu.au. Available at: <https://studyonline.uts.edu.au/blog/how-become-communications-manager>.

Training.gov.au. (2025). Available at: <https://training.gov.au/training/details/bsb40820/qualdetails> [Accessed 26 Nov. 2025].

Training.gov.au. (2026). Available at: <https://training.gov.au/training/details/BSB50620/qualdetails> [Accessed 15 May 2026].

Imperva. (2026). *Insecure Direct Object Reference (IDOR) | Best Practices* | Imperva. Learning Center. <https://www.imperva.com/learn/application-security/insecure-direct-object-reference-idor/>

Team, I. (2025, September 23). *Broken Authentication and IDOR – A Big but Solvable Problem*. Inspectiv.com; Inspectiv. <https://www.inspectiv.com/articles/broken-authentication-and-idor-a-big-but-solvable-problem>

Anas404. (2025, December 21). *Insecure Direct Object Reference (IDOR): Detect and Stop It*. Medium. <https://medium.com/@anas.abdo990088/insecure-direct-object-reference-idor-how-blue-teams-detect-and-stop-it-73aa67e8fd6d>

Ihouele Caury. (2025, July 30). *Web Attacks Mass- IDOR Enumeration (HTB)*. Medium. <https://medium.com/@ihouelecaury/web-attacks-mass-idor-enumeration-htb-c445e850fce7>

Invicti.com. (2017). *Insecure Direct Object References (IDOR)*. [online] Available at: <https://www.invicti.com/learn/insecure-direct-object-references-idor>

Sai Nandan Veerabrahmam (2024). *Guarding Against IDOR: Protecting Your Applications from Unauthorized Access*. [online] Medium. Available at: <https://medium.com/@nandansv1819/guarding-against-idor-protecting-your-applications-from-unauthorized-access-baac0f51c59c>

Stele, M. (2026). *Behind the Firewall: How Security Teams Detect Threats and Stop Attacks*. [online] Medium. Available at: <https://stele-miha.medium.com/behind-the-firewall-how-security-teams-detect-threats-and-stop-attacks-ef635285518a> [Accessed 14 May 2026]

OWASP (2013). *Insecure Direct Object Reference Prevention* • OWASP Cheat Sheet Series. [online] Owasp.org. Available at: [https://cheatsheetseries.owasp.org/cheatsheets/Insecure Direct Object Reference Prevention Cheat Sheet.html](https://cheatsheetseries.owasp.org/cheatsheets/Insecure_Direct_Object_Reference_Prevention_Cheat_Sheet.html)

Mozilla.org. (2025). *Insecure Direct Object Reference (IDOR) - Security* | MDN. [online] Available at: <https://developer.mozilla.org/en-US/docs/Web/Security/Attacks/IDOR>.

madison (2025). *How To Protect Your Data Against IDOR Attacks* - Congruity 360. [online] Congruity 360. Available at: <https://www.congruity360.com/blog/how-to-protect-your-data-against-idor-attacks/>

IDOR Vulnerabilities: Guide, How to Find, and Prevention. (2024, July 2). ZeroThreat. <https://zerothreat.ai/blog/understanding-idor-vulnerability-and-how-to-prevent-it>

hadrian.io. (2026). *Insecure Direct Object Reference (IDOR) - A Deep Dive*. [online] Available at: <https://hadrian.io/blog/insecure-direct-object-reference-idor-a-deep-dive>.

Palo Alto Networks. (2015). *What is an Incident Response Playbook?* [online] Available at: <https://www.paloaltonetworks.com/cyberpedia/what-is-an-incident-response-playbook>.

PUBLIC PORTFOLIO COPY